

Consent & Data-Protection Pack

Working draft for the clinic's data-protection adviser to review and sign off

Version 1.0 · Draft for review · 30 July 2026 · Prepared by WILBA for The Schoeman Clinic

How to read this. There are two parts. **Part A** is the short wording that goes on the forms: just a tick box and one line, and that is all the patient ever sees. **Part B** is the detail behind it, for the data-protection adviser to review and sign off once. The patient never reads Part B; the full terms they can click through to are the existing Privacy Policy.

PART A — FOR THE FORM BUILDER

The form copy: what the patient actually sees

Short and simple. Each patient sees a tick box and one line, with a link to the Privacy Policy if they want the full detail. Required boxes are unticked by default; optional boxes are clearly optional.

On the enquiry form

Enquiry consent

- ☐ I consent to The Schoeman Clinic using my details, including any health information I share, to respond to my enquiry and guide me through the next steps. ([See our Privacy Policy.](#)) **REQUIRED**
- ☐ Keep me updated with clinic news and health information by email. **OPTIONAL**

☐ Email ☐ WhatsApp ☐ SMS / phone. How would you like us to contact you about your care?

WhatsApp is used for appointment reminders and service messages, not marketing. You can update your preferences or withdraw your consent at any time.

On the registration form

Registration consent

- ☐ I confirm my details are accurate and I understand how The Schoeman Clinic will use my information to provide my care, as set out in the [Patient Privacy Policy](#). **REQUIRED**
- ☐ Keep me updated with clinic news and updates by email. **OPTIONAL**

☐ Email ☐ WhatsApp ☐ SMS / phone. How we contact you about your care.

Carry the contact and email preference across from the enquiry rather than asking again, unless it was not captured cleanly.

The reference pack behind the wording

Plain-English summary

This part turns the clinic's consent capture into something defensible under UK GDPR and PECR as communications move into GoHighLevel. It sets out the lawful basis for each activity, how long information is kept, patients' rights, the systems that touch patient data and how it moves internationally, and the specific edits the existing privacy policies need. It is written to be handed to your data-protection adviser for final sign-off before anything goes live.

Context we have worked from

- **Jurisdiction:** UK. Clinic established in the UK, CQC registered; patients may be international but require a UK address. Governing regime: UK GDPR + Data Protection Act 2018 + PECR.
- **Data type:** special-category (health) data. Even at enquiry, the "reason for enquiry" can reveal health information, so Article 9 applies from the first touchpoint.
- **Patients:** adults only (18+). No children's data is processed.
- **Marketing:** email + newsletter (moving from MailChimp to GoHighLevel). WhatsApp is used for the shared inbox and appointment reminders (service), not marketing. Retargeting ads (Google/Facebook/Instagram) are referenced in the current website policy but not confirmed as in use.
- **Controller / processor:** the clinic is the data controller. Semble and GoHighLevel and others are processors acting on the clinic's instructions.

1 · Why the enquiry wording reads as it does

The enquiry form collects: name, surname, email, phone, sex at birth, reason for enquiry (drop-down), referral source. Because the reason can reveal health information, we capture explicit consent to handle it, then keep marketing separate and optional.

The full version of the required consent

We use the information you provide to respond to your enquiry and guide you through the next steps. Because your enquiry may include information about your health, we ask for your explicit consent to handle it for this purpose.

☐ **I consent to The Schoeman Clinic using the information in this enquiry, including any health-related details, to respond and help me take the next steps.**

Unticked by default. On the form this is shortened to the single line in Part A; this longer version is the reasoning for the adviser.

2 · Why the registration wording changes

The registration form collects full medical history and identity. For a patient receiving care the basis shifts from consent to contract plus provision of health care, so the wording changes accordingly.

The basis for a patient in care

We use the information on this form to provide your healthcare, keep your medical records, arrange tests and prescriptions, and manage your appointments and billing. We handle your health information under UK GDPR Article 9(2)(h) (provision of health care) and the Data Protection Act 2018.

Note for build: replace every “EU GDPR” reference on the Semble registration and consent forms with “UK GDPR”.

3 · Marketing consent — how to capture it

- **Design:** capture explicit, per-channel opt-in ONCE, cleanly, at the enquiry stage, using separate unticked boxes. Do not bundle “email and WhatsApp” into one tick, and do not pre-tick.
- **Separation:** keep marketing (newsletters, clinic updates) clearly separate from service messages (appointment reminders, results logistics). This keeps consent “specific”.
- **Email:** email marketing needs consent or a valid PECR soft opt-in; every send needs a working unsubscribe and a genuine sender identity. Newsletters moving from MailChimp to GoHighLevel must carry only contacts with a valid basis; do not assume the whole patient list is opted in.
- **WhatsApp:** treat any future WhatsApp marketing as needing its own explicit opt-in plus Meta-approved templates. For now WhatsApp stays service-only, which matches Dr Gina’s wish not to “bombard” patients.
- **Record + fix:** record what each person consented to, when, how, and which version of the notice they saw. Important: Semble currently auto-marks SMS/email consent on registration; that is not valid consent and should be replaced with a genuine opt-in captured as above.

4 · Lawful-basis table

Activity	Lawful basis (Art 6)	Health-data basis (Art 9)
Responding to an enquiry (incl. health reason)	Consent — Art 6(1)(a)	Explicit consent — Art 9(2)(a)
Providing healthcare (records, tests, prescriptions)	Contract — Art 6(1)(b)	Provision of health care — Art 9(2)(h)
Appointment reminders / service messages	Contract / legitimate interests	n/a
Email newsletter / clinic marketing	Consent — Art 6(1)(a) + PECR	n/a
Payment processing	Contract — Art 6(1)(b)	n/a
Website analytics, cookies, retargeting	Consent — PECR (cookie banner)	n/a

5 · Retention — how long information is kept

Information type	Suggested retention	Note
Patient clinical records (held in Semble)	~8 years after last treatment (adults)	Align to the clinic's clinical records policy; confirm.
Enquiries that do not become patients	6–12 months, then delete or anonymise	Unless they have opted into marketing.
Operational / CRM records (GoHighLevel)	Match the record they relate to	Review annually; do not keep messages indefinitely.
Marketing contacts & consent records	Until withdrawn; refresh if inactive ~24 months	Keep the consent audit trail even after removal.
Billing & financial records	~6 years	HMRC / accounting requirement.

Periods are the clinic's decision; these are common private-healthcare benchmarks for the adviser to confirm and document.

6 · Patients' rights over their information

Patients can exercise the following rights, and the clinic responds within one calendar month (UK GDPR):

- **Access** a copy of their information (subject access request), **correct** it, and ask for **erasure**.
- **Restrict** or **object** to certain processing, and request **portability** of data they provided.
- **Withdraw consent** at any time, as easily as it was given. Withdrawing marketing consent never affects a patient's care.

Erasure is limited where records must be kept for clinical or legal retention. Name a clear route (a contact and email) for these requests in the privacy notice.

7 · Sub-processor register (updated)

Provider	What data	Location	Transfer mechanism
Semble	Clinical records, admin	UK	n/a
GoHighLevel (HIPAA tier)	Operational CRM, inbox, forms, comms	US	UK IDTA in DPA
WhatsApp / Meta Cloud API	Patient messages	GB storage	Meta DPA / adequacy
Stripe	Payment data	UK / EU	n/a / SCCs
The Doctors Laboratory (TDL)	Blood-test data	UK	n/a
Pharmacies (PCCA, Fagron, Zen, Natural Dispensary, Nordic, Vibrant)	Prescription / order data	UK / US	confirm per vendor
Google Analytics / Maps	Website usage	US	confirm (consent-gated)
MailChimp (being retired → GHL)	Newsletter emails	US	confirm / remove on migration

Each processor needs an **Article 28 data processing agreement** in place, binding them to act only on the clinic’s instructions and to notify the clinic of any breach without undue delay. A reportable personal-data breach must reach the **ICO within 72 hours**.

8 · International transfers

Some processors (GoHighLevel, certain pharmacies, and analytics) are in the US. Those transfers rely on the **UK International Data Transfer Agreement (IDTA)**, or the UK Addendum to the EU Standard Contractual Clauses, within each processor’s DPA, supported by a **Transfer Risk Assessment**. GoHighLevel is on its HIPAA tier. Confirm the signed IDTA and DPA with GoHighLevel are in place before go-live.

9 · Privacy-notice updates needed

- Terminology:** replace every “EU GDPR” reference with “UK GDPR” across the Semble registration form, consent form, and both privacy policies.
- Add processor:** add GoHighLevel as a processor (operational CRM, inbox, forms, communications; US, HIPAA tier, UK IDTA).

- **Add processor:** add WhatsApp / Meta Cloud API as a processor for patient messaging (GB storage).
- **Update:** the website policy names MailChimp for newsletters; update to reflect the move to GoHighLevel (retain MailChimp only if still used).
- **Confirm / fix:** the website policy references retargeting ads via Google, Facebook and Instagram. Confirm whether these are actually in use; if not, remove the clause; if yes, ensure the cookie banner captures consent for them (PECR).
- **Cookies:** ensure a compliant cookie consent banner is in place for non-essential cookies (analytics, maps, any retargeting).
- **Retention & rights:** state the retention periods and the patient rights above, with a named data-protection contact and the subject-access-request route.

10 · Data protection by design — DPIA & accountability

Because this involves special-category (health) data at scale, a new operational CRM (GoHighLevel), and international transfer, a **Data Protection Impact Assessment (DPIA)** is expected under UK GDPR Article 35. We recommend completing a short DPIA for the GoHighLevel rollout before launch; your data adviser should own and sign it. WILBA can provide a pre-filled DPIA outline to speed this up.

11 · Before this goes live — data-person checklist

- ☐ Confirm the lawful bases above for special-category data at enquiry and in care
- ☐ Approve the final enquiry and registration consent wording
- ☐ Confirm the data controller's legal entity name and ICO registration
- ☐ Name a data-protection contact (and DPO if applicable) and the subject-access-request route
- ☐ Set and document the retention periods; configure deletion of non-converting enquiry data
- ☐ Confirm the newsletter list only contains contacts with a valid basis before the MailChimp → GHL migration
- ☐ Replace Semble's auto-marked consent with genuine captured opt-in
- ☐ Put a signed UK IDTA and Article 28 DPA in place with GoHighLevel and other US processors
- ☐ Complete a DPIA for the GoHighLevel rollout
- ☐ Confirm whether retargeting ads are in use and fix the website policy accordingly
- ☐ Confirm patient "active / inactive / archived" status governs who can be marketed to
- ☐ Update EU → UK GDPR references everywhere

12 · Review & sign-off

For the reviewing data team: please confirm the items in section 11, note any changes, and complete the sign-off below. WILBA will action any wording or build changes you flag.

Reviewed by	Role	Confirmed / changes requested	Date

This is a working draft to speed up your compliance process. Have a qualified lawyer or your data-protection adviser in the relevant jurisdiction review and sign it off before it goes live.

Prepared by WILBA for The Schoeman Clinic · Version 1.0 · 30 July 2026